

Enhanced Attack Report

DAMASCENED PEACOCK

Generated on 2025-10-11

Disclaimer

This report has been generated automatically and should be used for informational purposes only. To generate this report, Large Language Models (LLMs) were used to analyze the provided data. This technology is not perfect and may generate incorrect or misleading results. The results should be reviewed by a human expert before taking any action based on the information provided.

Definitions

Pre-Conditions: Conditions that must be true to execute the attack steps in the milestone.

Post-Conditions: Traces that an attacker leaves behind after executing the attack steps in the milestone.

Attack Steps: Steps that an attacker would take to achieve the goal of the milestone.

MITRE Technique: Techniques from the MITRE ATT&CK; framework that are relevant to the milestone.

STIX

Malware Name: DAMASCENED PEACOCK

Malware Description: • DAMASCENED PEACOCK is a lightweight downloader targeting Windows. • The analysed sample was for 32-bit (x86) Windows. It supports downloading a 64-bit onward stage. • The malware was observed in a spear-phishing campaign which took place in the autumn of 2024. • DAMASCENED PEACOCK is downloaded and executed by a code signed first stage. • DAMASCENED PEACOCK is the second of 3 stages and is responsible for downloading the final stage and executing it via a COM Hijack. • DAMASCENED PEACOCK implements Defence Evasion techniques such as XOR based string obfuscation and dynamic resolution of Win32 APIs.

Quick Overview

Milestone m1

a1. Gather Victim Identity Information as used by the malware (T1592.002)

Milestone m2

a2. Phishing: Spearphishing Link as used by the malware (T1566.002)

Milestone m3

a3. User Execution: Malicious File as used by the malware (T1204.002)

a4. Inter-Process Communication: Component Object Model as used by the malware (T1569.002)

Milestone m4

a5. Deobfuscate/Decode Files or Information as used by the malware (T1140)

a6. Obfuscated Files or Information: Dynamic API Resolution as used by the malware (T1027.007)

a7. Subvert Trust Controls: Code Signing as used by the malware (T1553.002)

a8. Masquerading as used by the malware (T1036)

Milestone m5

a9. Application Layer Protocol: Web Protocols as used by the malware (T1071.001)

Attack Graph

Attack graph image not found.

Milestone *m1*

Attack Step *a1*

=====

Name: Gather Victim Identity Information as used by the malware

Description: The architecture of the current process is analyzed by the malware to ascertain whether the victim's system operates on a 32-bit or 64-bit architecture. Subsequently, a payload commensurate with the determined architecture is downloaded.

Pre-Conditions:

- The malware has successfully infected the victim's system.

Post-Conditions:

- Potential for further malware infections and lateral movement within the network.
- Traces of tunneling activities using PuTTY's Plink tool.
- Damage to system integrity and stability.
- Modified registry entries related to COM hijacking.
- Modified system files with malicious code injections.
- Evidence of data transfer via file sharing services (e.g., temp[.]sh).
- Deleted or altered original files to cover tracks.
- New files created in %LOCALAPPDATA%\KeyStore\ directory (e.g., KeyProv.dll, SnippingTool.dll).
- Data exfiltration to attacker-controlled servers.
- Logs containing suspicious activity and command executions.
- Loss of sensitive information and intellectual property.
- Compromised system with persistent backdoor access.

MITRE Technique

ID: T1592.002

Name: Gather victim host information: software

Description: Adversaries may gather information about the victim's host software that can be used during targeting. Information about installed software may include a variety of details such as types and versions on specific hosts, as well as the presence of additional components that might be indicative of added defensive protections (ex: antivirus, SIEMs, etc.).

More info: <https://attack.mitre.org/techniques/T1592/002>

Milestone *m2*

Attack Step a2

=====

Name: Phishing: Spearphishing Link as used by the malware

Description: Spear-phishing emails containing links to malicious websites were utilized in the execution of the attack. Upon user interaction with these links, redirection to sites hosting the initial malware payload (DAMASCENED PEACOCK) was effectuated. Subsequent payloads were subsequently downloaded and executed by this initial stage, culminating in the compromise of the victim's system.

Pre-Conditions:

- The attacker possesses knowledge of email protocols and security measures to bypass basic spam filters.
- The attackers have gathered sufficient information about the target audience to craft convincing spearphishing emails.
- A computer system with internet connectivity is available to the attacker.
- A target audience exists who would be susceptible to a phishing campaign.

Post-Conditions:

- Registry key modifications
- System compromise
- Data exfiltration
- Execution of arbitrary commands
- Potential data manipulation or deletion
- Event log entries indicating suspicious activity
- Network reconnaissance
- Network traffic logs showing communication with C2 servers
- Access logs for compromised systems
- Shadow copies of files
- Lateral movement within the network
- Deleted files (potentially recovered through forensics)
- Installation of persistent backdoors
- New files created and executed
- Firewall logs recording unusual connections
- Modified system configurations

MITRE Technique

ID: T1566.002

Name: Phishing: spearphishing link

Description: Adversaries may send spearphishing emails with a malicious link in an attempt to gain access to victim systems. Spearphishing with a link is a specific variant of spearphishing. It is different from other forms of spearphishing in that it employs the use of links to download malware contained in email, instead of attaching malicious files to the email itself, to avoid defenses that may inspect email attachments. Spearphishing may also involve social engineering techniques, such as posing as a trusted source.

More info: <https://attack.mitre.org/techniques/T1566/002>

Milestone *m3*

Attack Step *a3*

=====

Name: User Execution: Malicious File as used by the malware

Description: A phishing email campaign, purportedly originating from a reputable news organization, is disseminated to Ministry of Defense personnel. These emails contain hyperlinks that, upon user activation, redirect recipients to download a file presented as a PDF document. Concurrently with the display of a decoy PDF, a malicious downloader designated "Damascened Peacock" is executed in the background. This downloader facilitates the establishment of unauthorized access on the victim's system and the subsequent download of additional malware components.

Pre-Conditions:

- The user executes the malicious file.
- A user account with sufficient permissions exists on the target system.

Post-Conditions:

- Potential for further malware infections
- Data exfiltration
- Altered file timestamps and permissions
- System instability
- Loss of sensitive information
- New user accounts created
- Network connections to malicious C2 servers
- Compromised system security
- Dropped executable files with suspicious names
- Unusual process activity logs
- Backdoor access established
- Modified system registry entries

MITRE Technique

ID: T1204.002

Name: User execution: malicious file

Description: An adversary may rely upon a user opening a malicious file in order to gain execution. Users may be subjected to social engineering to get them to open a file that will lead to code execution. This user action will typically be observed as follow-on behavior from Spearphishing Attachment. Adversaries may use several types of files that require a user to execute them, including .doc, .pdf, .xls, .rtf, .scr, .exe, .lnk, .pif, .cpl, and .reg.

More info: <https://attack.mitre.org/techniques/T1204/002>

Attack Step *a4*

=====

Name: Inter-Process Communication: Component Object Model as used by the malware

Description: Inter-Process Communication (IPC) through the Component Object Model (COM) is exploited by DAMASCENED PEACOCK to execute its third stage payload. The explorer.exe process, responsible for managing the graphical user interface (GUI) on Windows systems, is identified and targeted by the malware. Code injection techniques are employed by DAMASCENED PEACOCK to insert its third-stage code into explorer.exe. This allows the malware to leverage the privileges and execution context of explorer.exe, potentially bypassing security measures that might otherwise impede malicious code execution. Remote Procedure Call (RPC) mechanisms within COM are utilized by DAMASCENED PEACOCK to execute the injected code. Functions within explorer.exe are called by the malware as if they were its own, effectively hijacking the process and running its malicious payload under the guise of legitimate system activity.

Pre-Conditions:

- The malware has been successfully executed.
- A Windows operating system is present.
- The target application supports COM interfaces.

Post-Conditions:

- New files created or modified (executables, DLLs, configuration files)
- Modified timestamps on files
- System compromise
- Modified registry entries
- Presence of backdoors and rootkits
- Disruption of normal system operations
- Deleted or overwritten original files
- Potential for further malware installation and execution
- Loss of sensitive information
- Evidence of data exfiltration
- Data theft
- Unusual network connections to C2 servers
- Log entries indicating suspicious activity
- Network access
- Remote control of infected machine
- Traces in event logs
- Altered system settings

MITRE Technique

ID: T1569.002

Name: System services: service execution

Description: Adversaries may abuse the Windows service control manager to execute malicious commands or payloads. The Windows service control manager (services.exe) is an interface to manage and manipulate services. The service control manager is accessible to users via GUI components as well as system utilities such as sc.exe and Net.

More info: <https://attack.mitre.org/techniques/T1569/002>

Milestone *m4*

Attack Step *a5*

=====

Name: Deobfuscate/Decode Files or Information as used by the malware

Description: String obfuscation techniques employed by the malware families SnipBot, ShadyHammock, SingleCamper, and DustyHammock are primarily characterized by XOR-based encoding. This method involves the encryption of critical data elements, such as API function names, C2 domains, and registry keys, using the XOR operation in conjunction with a predetermined key. Decryption necessitates the application of the reverse XOR operation with the corresponding key. The implementation of XOR encoding likely entails a bitwise operation between each character in the original string and the designated key. Management of the key itself may involve hardcoding within the malware binary, retrieval from a C2 server during communication, or derivation based on system-specific factors such as timestamps. Successful deobfuscation yields crucial information enabling the malware to establish connections with its Command and Control (C2) server for receiving instructions and transmitting stolen data, interact with the operating system through API function names, and target specific files or directories by accessing registry keys. Specialized tools employed in malware analysis, such as hex editors, debuggers, and dedicated malware analysis software, facilitate the detection and reversal of common obfuscation techniques like XOR encoding.

Pre-Conditions:

- Computational resources sufficient for processing the malware code.
- The malware code contains obfuscated or encoded files or information.
- Knowledge of the malware's structure and potential obfuscation methods.
- The malware has been downloaded and is present in the environment.
- Access to the malware binary.

Post-Conditions:

- Logs of file transfers and network activity.
- Potential for further lateral movement within the network.
- Traces of dynamic API resolution techniques used by the malware.
- Evidence of XOR-based string obfuscation in malware code.
- Modified registry keys (HKCU\SOFTWARE\AppDataSoft\Software).
- Modified or deleted original files.
- Compromised system with malware installed and running.
- Damage to reputation and trust.
- 92.250[.]104).
- Network connections to 91.92.250[.]104.
- Loss of sensitive information.
- New files on the system (single.dll, trem1, trem3, dsutil.exe, asfsutil.exe).

MITRE Technique

ID: T1140

Name: Deobfuscate/decode files or information

Description: Adversaries may use Obfuscated Files or Information to hide artifacts of an intrusion from analysis. They may require separate mechanisms to decode or deobfuscate that information depending

on how they intend to use it. Methods for doing that include built-in functionality of malware or by using utilities present on the system.

More info: <https://attack.mitre.org/techniques/T1140/>

Attack Step a6

=====

Name: Obfuscated Files or Information: Dynamic API Resolution as used by the malware

Description: Dynamic API Resolution is an obfuscation technique employed by malware to conceal its functionality. This technique involves the calculation of unique hash values for each intended Windows API function, serving as code identifiers in lieu of actual function names. At runtime, these hashed values are utilized to dynamically resolve corresponding API addresses. Consequently, the malware's code does not contain explicit function name references, hindering static analysis efforts aimed at determining its purpose.

Pre-Conditions:

- A vulnerable system with an operating system capable of executing the malware.
- Network connectivity is required for the malware to communicate with its command and control server.
- The malware executable must be present on the target system.
- The malware is running within a system's process space.
- The system has libraries containing the targeted APIs.

Post-Conditions:

- System compromise
- Data exfiltration
- Damage to reputation
- Deleted or altered log files
- Snapshot of local AD database
- Potential for ransomware deployment
- Registry modifications
- Loss of sensitive information
- New files created and executed
- Unusual process activity in event logs
- Network traffic logs (C2 communication)
- Disruption of services
- Modified system configurations

MITRE Technique

ID: T1027.007

Name: Obfuscated files or information: dynamic api resolution

Description: Adversaries may obfuscate then dynamically resolve API functions called by their malware in order to conceal malicious functionalities and impair defensive analysis. Malware commonly uses various Native API functions provided by the OS to perform various tasks such as those involving processes, files, and other system artifacts.

More info: <https://attack.mitre.org/techniques/T1027/007>

Attack Step a7

=====

Name: Subvert Trust Controls: Code Signing as used by the malware

Description: Code signing mechanisms are susceptible to subversion through the acquisition of legitimate digital certificates by malicious actors. These certificates, potentially obtained through compromised accounts or stolen credentials, enable the signing of malicious code with a veneer of authenticity. This practice circumvents security controls by inducing trust in seemingly legitimate software. Operating systems and security software reliant on signature verification may grant access to signed malware, facilitating its execution. The deceptive appearance presented by signed malware hinders detection and removal efforts. The consequences of this subversion include the potential for stealthy execution with elevated privileges, enabling attackers to exert greater control over compromised systems. Furthermore, traditional antivirus software, often dependent on signature-based detection, may be rendered ineffective against signed malware. This increases the potential for extensive damage, encompassing data theft, backdoor installation, and system disruption.

Pre-Conditions:

- A software development environment is available.
- A malicious actor possesses a valid code signing certificate or has obtained one through illegitimate means.
- Access to a computer system capable of executing compiled code.
- Tools for creating and manipulating digital certificates are accessible.

Post-Conditions:

MITRE Technique

ID: T1553.002

Name: Subvert trust controls: code signing

Description: Adversaries may create, acquire, or steal code signing materials to sign their malware or tools. Code signing provides a level of authenticity on a binary from the developer and a guarantee that the binary has not been tampered with. The certificates used during an operation may be created, acquired, or stolen by the adversary. Unlike Invalid Code Signature, this activity will result in a valid signature.

More info: <https://attack.mitre.org/techniques/T1553/002>

Attack Step a8

=====

Name: Masquerading as used by the malware

Description: Executable files are presented with icons and filenames suggestive of PDF documents, thereby inducing users into executing malicious code under the false presumption of harmlessness.

Pre-Conditions:

- The malware has access to the registry.
- The malware has the ability to execute code.
- A target system running Windows.
- The malware has been successfully deployed on a target system.

- The ability to execute code on the target system.
- Access to the target system's file system and registry.

Post-Conditions:

- Registry key modifications related to COM hijacking.
- Registry keys and folders associated with the backdoor are deleted.
- A benign copy of explorer.exe is executed.
- Files downloaded from the C2 server(s).
- Log entries related to process termination and restarts (explorer.exe).
- Network connections to the C2 server(s).

MITRE Technique

ID: T1036

Name: Masquerading

Description: Adversaries may attempt to manipulate features of their artifacts to make them appear legitimate or benign to users and/or security tools. Masquerading occurs when the name or location of an object, legitimate or malicious, is manipulated or abused for the sake of evading defenses and observation. This may include manipulating file metadata, tricking users into misidentifying the file type, and giving legitimate task or service names.

More info: <https://attack.mitre.org/techniques/T1036/>

Milestone *m5*

Attack Step *a9*

=====

Name: Application Layer Protocol: Web Protocols as used by the malware

Description: The malware, designated DAMASCENED PEACOCK, utilizes HTTP for communication with its Command and Control (C2) server. Communication is established via the Windows WinHTTP Application Programming Interface (API), targeting port 8080 on the C2 server. Information pertaining to the infected system or instructions from the attacker are transmitted via HTTP POST requests to the C2 server.

Pre-Conditions:

- An internet connection is available to the infected system.
- The malware is configured with the necessary information to connect to the web server (e.g., IP address, port).
- The malware possesses the necessary code to parse and interpret web responses.

Post-Conditions:

- System compromise
- Data exfiltration
- New files created or modified (e.g., DLLs, executables)
- Registry modifications
- Unusual user activity logs
- Malware persistence
- File system alterations
- Network communication with C2 server
- Shadow copies of compromised files
- Modified system configurations
- Network traffic logs showing connections to C2 server
- System event logs recording process creation, file access, and registry changes

MITRE Technique

ID: T1071.001

Name: Application layer protocol: web protocols

Description: Adversaries may communicate using application layer protocols associated with web traffic to avoid detection/network filtering by blending in with existing traffic. Commands to the remote system, and often the results of those commands, will be embedded within the protocol traffic between the client and server.

More info: <https://attack.mitre.org/techniques/T1071/001>